



Model-based risk assessment for cyber physical systems security

Ashraf Tantawy^{a,*}, Sherif Abdelwahed^a, Abdelkarim Erradi^b, Khaled Shaban^b

^a Department of Electrical and Computer Engineering, Virginia Commonwealth University, VA 23220 USA

^b Computer Science and Engineering Department, Qatar University, Doha, Qatar

ARTICLE INFO

Article history:

Received 15 July 2019

Revised 20 February 2020

Accepted 30 April 2020

Available online 27 May 2020

Keywords:

CPS

Security

Safety

Hybrid automaton

Hybrid system

Modeling

Attack tree

Penetration testing

Risk assessment

Testbed

SCADA

Industrial automation

Modbus

CSTR

ABSTRACT

Traditional techniques for Cyber-Physical Systems (CPS) security design either treat the cyber and physical systems independently, or do not address the specific vulnerabilities of real time embedded controllers and networks used to monitor and control physical processes. In this work, we develop and test an integrated model-based approach for CPS security risk assessment utilizing a CPS testbed with real-world industrial controllers and communication protocols. The testbed monitors and controls an exothermic Continuous Stirred Tank Reactor (CSTR) simulated in real-time. CSTR is a fundamental process unit in many industries, including Oil & Gas, Petrochemicals, Water treatment, and nuclear industry. In addition, the process is rich in terms of hazardous scenarios that could be triggered by cyber attacks due to the lack of possible mechanical protection. The paper presents an integrated approach to analyze and design the cyber security system for a given CPS where the physical threats are identified first to guide the risk assessment process. A mathematical model is derived for the physical system using a hybrid automaton to enumerate potential hazardous states of the system. The cyber system is then analyzed using network and data flow models to develop the attack scenarios that may lead to the identified hazards. Finally, the attack scenarios are performed on the testbed and observations are obtained on the possible ways to prevent and mitigate the attacks. The insights gained from the experiments result in several key findings, including the expressive power of hybrid automaton in security risk assessment, the hazard development time and its impact on cyber security design, and the tight coupling between the physical and the cyber systems for CPS that requires an integrated design approach to achieve cost-effective and secure designs.

© 2020 Elsevier Ltd. All rights reserved.

1. Introduction

Cyber-Physical Systems (CPS) integrate physical elements, for sensing and actuation, with cyber elements, for computation and communication, to automate and control industrial processes. CPS is pervasively used in critical application domains such as health care, traffic management, manufacturing, and energy infrastructures. These systems are increasingly adopting commercial and open source software components and standard communication protocols in order to reduce infrastructure costs and ease integration and connection with corporate networks. However, this has exposed such systems to new security threats and made them a prime target for cyber-attacks to disrupt their normal operation. This may result in profound and catastrophic impacts such as endangering public safety and economic stability. Despite ongoing efforts to secure and protect CPS, these critical infrastructure com-

ponents remain vulnerable to cyber attacks. Recent intensified sophisticated attacks on these systems have stressed the importance of methodologies and tools to assess and manage cyber security risks (Alcaraz and Zeadally, 2015). Additionally, it is necessary to identify and address safety and security requirements earlier as part of the system design process (Friedberg et al., 2017).

Traditional IT security risk assessment is a well-established domain, guided by several international standards, e.g., (Stoneburner et al., 2002). More recently, standards emerged to address the specific needs of CPS domains, such as IEC 62443 for securing industrial automation and control systems. However, these standards provide best practices for the security system independent of the monitored physical system. It is the responsibility of the CPS designer to integrate the safety and security aspects of the CPS, often in an ad-hoc manner. Realizing this gap, IEC/TC65 plenary board proposed a new group to consider how to bridge functional safety and cyber security for industrial automation systems (Kanamaru, 2017).

In this work, we propose a model-based design approach where physical system modeling, data flow modeling, and attack trees are

* Corresponding author.

E-mail addresses: amatantawy@vcu.edu (A. Tantawy), sabdelwahed@vcu.edu (S. Abdelwahed), erradi@qu.edu.qa (A. Erradi), khaled.shaban@qu.edu.qa (K. Shaban).

Nomenclature

CPS	Cyber-Physical System
CSTR	Continuous Stirred Tank Reactor
SCADA	Supervisory Control And Data Acquisition
WSN	Wireless Sensor Network
BPCS	Basic Process Control System
SIS	Safety Instrumented System
HMI	Human Machine Interface
DMZ	DeMilitarized Zone
HAZOP	HAZard and OPerability
SIF	Safety Instrumented Function
IPL	Independent Protection Layer
GUI	Graphical User Interface
P&ID	Process & Instrumentation Diagram
MITM	Man In The Middle
SSH	Secure Socket Shell
DoS	Denial of Service
PID	Proportional Integral Derivative
LOPA	Layer Of Protection Analysis
TMEL	Target Mitigated Event Likelihood

integrated to deliver a unified design framework of safe and secure CPS. First, the physical system modeling documents all the system components and their interaction interfaces including system sensors, controllers, and the supporting networks and protocols. Then we identify the data flow and information exchange between the system components to enable monitoring and controlling the physical process. The resulting system model and data flow model are used as inputs for threat modeling using attack trees. The latter are conceptual diagrams describing the system threats and possible attacks to realize those threats (Mauw and Oostdijk, 2005).

We summarize the key contributions of the paper as follows: (1) the introduction of hybrid system automaton as a powerful tool for cyber security risk assessment, and countermeasure & mitigation design. Development of an integrated safety-security model-based co-design approach for CPS. The approach integrates physical and cyber models for attack scenario generation, risk assessment, and countermeasures design. Providing insight on key research directions as revealed throughout the design and implementation of the case study CPS.

We applied and empirically validated our proposed model-based approach for CPS security risk assessment on a CPS testbed that monitors and controls an exothermic Continuous Stirred Tank Reactor (CSTR) simulated in real-time. CSTR is a widely used model for chemical reactor engineering. This process is selected because of its practical importance and its associated hazards that can be triggered by cyber attacks with no possible mechanical protection, including reactor overflow and thermal runaway with the risk of fire, explosion or environmental hazards (Friedberg et al., 2017). A technical report detailing the design of the CPS testbed along with the implementation of the CSTR simulator, the Basic Process Control System (BPCS) and the Safety Instrumented System (SIS) are available online.¹

The rest of the paper is organized as follows: Section 2 discusses important related work. Section 3 presents the overall architecture for the CPS used as a case study throughout the paper. Section 4 introduces the hybrid automaton approach for hazard identification. The design of cyber attacks is presented in Section 5. Section 6 summarizes the penetration testing results and the formal risk assessment. The key insights gained from the case study

are summarized in Section 7, and the paper is concluded with future research directions in Section 8.

2. Related work

In addition to international standards, the research community recently started to address the CPS security problem in non-traditional ways. A survey on CPS security, challenges, and solutions could be found in Ashibani and Mahmoud (2017). A review of risk assessment methods for SCADA systems is conducted in Cherdantseva et al. (2016), including attack trees, countermeasure trees, petri nets, as well as several quantitative risk measures. CPS security for industrial processes has been studied in Huang et al. (2015), where a multi-layer cyber-security protection architecture is proposed. A system for runtime attack detection and prevention for industrial control systems is proposed in Ylmaz and Gönen (2018). The application of attack-defense trees to analyze cyber security for CPS is reported in Ji et al. (2016). The authors in Sabaliauskaite and Mathur (2015) proposed an integrated CPS safety and security lifecycle process, merging ISA84/IEC 61511 and ISA99/IEC 62443 lifecycle processes, where a combined failure and attack graph is proposed for risk assessment. A safety/security risk analysis approach that combines bowtie analysis for safety systems with attack tree analysis for security systems is considered in Abdo et al. (2018). CPS security for the electric power grid is discussed in Sridhar et al. (2012), where the authors proposed a risk assessment methodology and identified the potential threats for each component of the grid.

As a research aid, researchers build testbeds that represent scaled down versions of actual physical industrial control systems in order to provide a research environment that allows extensive attack-defense experimentation with realistic attack scenarios. The testbed facilitates the vulnerability and risk assessment, impact analysis of cyber-attacks on the controlled process, and risk mitigation, in order to enable the design and evaluation of effective detection and defense mechanisms. Several testbeds developed at various universities and national research labs have been reported in the literature for different CPS application domains, predominantly focusing on critical infrastructures such as the smart power grid testbeds presented in Hahn et al. (2013), Poudel et al. (2017) and Jarmakiewicz et al. (2017). One of the early power grid testbeds are the National SCADA TestBed (NSTB) (Craig, 2008) and Idaho National Labs (INL) SCADA Testbed which deploys real physical grid components including generators, transmitters, substations and controllers (Inl and Idaho National Laboratory, 2009). In addition to the energy domain, a smart transportation system testbed has been proposed in Koutsoukos et al. (2017). Industrial Control Systems SCADA testbed has been discussed in Morris et al. (2011), and a water treatment testbed is reported in Mathur and Tippenhauer (2016). However, these testbeds are either very costly to implement and maintain, making them unaffordable for most researchers, or they use commercial hardware and software components that are often treated as black boxes with little ability to model their inner working. The testbed we used for CPS security design, briefly presented in this paper, uses open hardware and software components, yet implements industrial standard communication protocols, e.g., Modbus/TCP.

Recently many CSTR-based testbeds were used to study cyber attacks on chemical processes. The study in Guan and Ge (2018) addressed the problem of joint distributed attack detection and secure estimation of the system states for a networked CPS over a wireless sensor network (WSN). A malicious adversary simultaneously launches a False Data Injection (FDI) attack at the physical system layer to intentionally modify the systems state and jamming attacks at the cyber layer to block the wireless transmission channels between sensors and remote estima-

¹ <https://github.com/qucse/CpsSecurity>.

tors. The discretized and linearized state-space model of the CSTR near the operating point is used to show the effectiveness of the approach. To improve the overall resilience of CPS, the authors in [Januario et al. \(2017\)](#) propose a framework based on a distributed middleware that integrates a multiagent topology. The proposed framework is evaluated using a CPS simulator composed of a CSTR benchmark system model, a Wireless Sensor and Actuator Networks (WSAN) and additional remote devices, including a remote controller, a server where the model of the plant is running and an HMI. Jamming and node loss attacks are carried out as experiments for assessing the proposed attack framework. The work in [Durand \(2018\)](#) develops a nonlinear system framework for understanding cyberattack-resilience of CSTR process using three control designs, where the focus is on data injection attacks on sensor measurements to impact the process safety. The study in [Wu et al. \(2018\)](#) integrates a neural network (NN)-based detection method and a Lyapunov-based model predictive controller for a class of nonlinear systems. A CSTR with constant volume is used to illustrate the application of the proposed NN-based detection method to handle cyber-attacks. A methodology for detecting abnormal events in aging Industrial Internet of Things (IIoT) has been developed in [Genge et al. \(2019\)](#). The authors developed an efficient anomaly detection methodology that uses the correlation among process variables in order to detect stealthy cyber-attacks, and presented extensive experimental results on a CSTR model. An approach has been proposed in [Paoletti et al. \(2019\)](#) to either certify that a given control system is safe under possible cyber-attacks on the measured data used for feedback and/or the commanded control signals, or alternatively synthesize a particular spoofing attack that corrupts the signals to make the closed-loop system unsafe. A two state CSTR has been used as testbed for implementing the approach. The research work in [Zhang et al. \(2018\)](#) employed a CSTR testbed to elucidate the dynamic interaction between feedback control and safety systems in the context of both model-based and classical control systems. To this aim, the interaction of a Model Predictive Control (MPC) system with a safety system is studied in the context of the Methyl isocyanate (MIC) hydrolysis reaction in a CSTR to avoid thermal runaway. The authors develop a specific action for the MPC to take when the safety system is activated due to significant feed disturbances that lead to thermal runaway conditions.

Most of the reviewed testbeds mainly use control-theoretic approaches for the detection of cyber-attacks on chemical processes using state estimation techniques. The approaches in these papers are largely based on theoretical mathematical analysis and can get intractable for realistic CPS. Unlike the work reported in this paper, none of the studies considered the integration of the physical and cyber aspects of the CPS for risk assessment and countermeasures design. Existing work mainly considers the model-based approach for the physical system only, disregarding the cyber system. In addition, the work in this paper uses a standard CPS architecture that resembles industrial installations with industry-standard hardware and software.

In this paper, we develop a model-based approach for CPS security risk assessment. Rather than abstract formulations, we experiment with the design process on an industrial CPS testbed. The key objective of the experiments is to verify the design approach and to gain insights that could be used by the research community for future refinements. The work presented in this paper differentiates itself from existing literature in three main aspects: (1) it follows a model-based approach to couple CPS safety and security throughout the whole lifecycle, (2) it proposes a formal approach to identify system hazards from a given physical model, rather than relying on expert opinion, and (3) it implements the whole risk assessment lifecycle from asset identification to mitigation design, via a case study on an actual testbed, which provides both a clear imple-

mentation methodology as well as an insight for further research work.

3. CPS testbed architecture

[Fig. 1](#) illustrates the overall CPS architecture used in this paper. The physical system is an exo-thermal Continuous Stirred Tank Reactor (CSTR) simulated in real-time. Simulation data is exchanged over an I/O physical data bus to both the Basic Process Control System (BPCS) and the Safety Instrumented System (SIS). The BPCS implements the process control functions while the SIS implements the process shutdown logic functions, and both run RT Linux OS. The monitoring workstation implements the Human Machine Interface (HMI) for the operator to monitor and control the plant. The HMI has access control mechanisms that allow different levels of control based on the user role (typically operator, supervisor, and engineer). [Fig. 2](#) shows the implemented HMI. A control network interconnects BPCS, SIS, Human Machine Interface (HMI) workstation, and the Engineering workstation. A firewall is configured to isolate the control network from the corporate network. A DeMilitarized Zone (DMZ) is formed to host the historian and real time data servers, following NIST proposed architecture ([Stouffer et al., 2015](#)). The RT Server runs the open source mysql database to store plant data for later retrieval by the HMI application and corporate financial analysis applications.

3.1. Physical system

We choose the Continuous Stirred Tank Reactor (CSTR) as the physical system for the testbed. The CSTR is an essential equipment in process plants where new products are formed from raw inlet reactants. The CSTR process possesses several features that make it a good choice for CPS security studies. First, the process variables to be controlled are closely-coupled, hence any change in one process variable will impact other variables as well and manifest itself in the overall process behavior. Second, the process has a number of potential safety hazard scenarios that may be produced by a cyber attack. Finally, mitigation layers for a number of safety hazards rely mainly on the control and safety systems, which are cyber systems that could be compromised by a cyber attack.

3.1.1. Process description

We consider an irreversible exothermic CSTR process, with a first order reaction in the reactant *A* to produce product *B* with rate *k* and a heat of reaction λ .



[Fig. 3](#) shows the Piping & Instrumentation Diagram (P&ID) for the reactor. The reactor vessel has an inlet stream carrying the reactant *A*, an outlet stream carrying the product *B*, and a cooling stream carrying the cooling fluid into the surrounding jacket to absorb the heat of the exothermic reaction. Reactant *A* enters the reactor with concentration C_{A0} , temperature T_0 and volumetric flow rate F_0 . A first order reaction takes place where a mole fraction of reactant *A* is consumed to produce product *B*. The outlet stream contains both reactant *A* and product *B*, with reactant *A* concentration C_A , outlet temperature T , and flow rate F . The outlet temperature T is the same as the reactor temperature. The coolant fluid flows into the reactor jacket with temperature T_{j0} and flow rate F_{j0} , and leaves the jacket with temperature T_j . The total coolant volume in the jacket is designated by V_j . The detailed mathematical model is developed in [Ashraf et al. \(2019\)](#).

3.1.2. Process measurement & control

The reactor temperature could be controlled by adjusting the coolant fluid inlet flow. A single variable control loop is used to regulate the reactor temperature. The control loop is composed

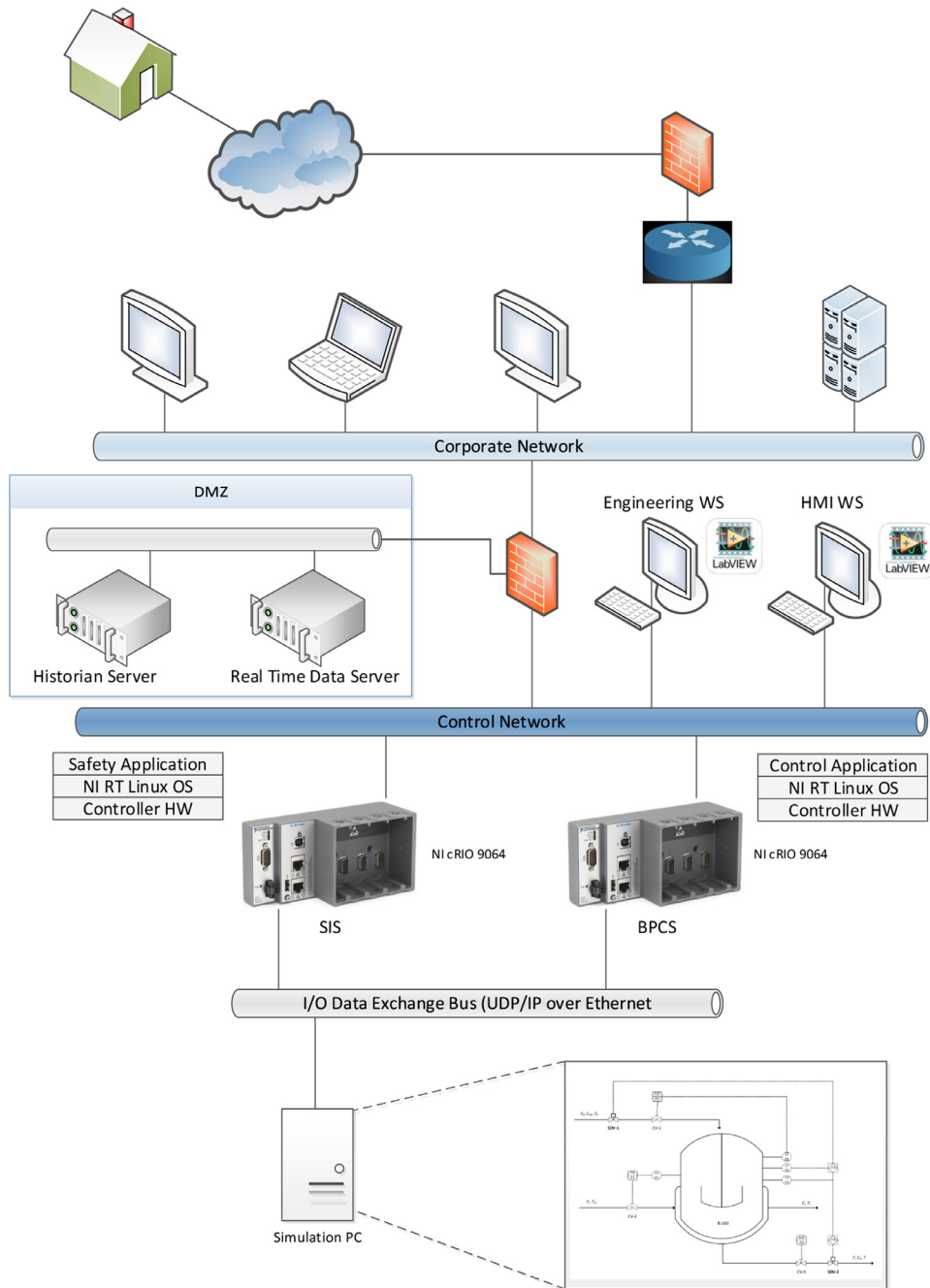


Fig. 1. CPS Testbed Architecture.

of a temperature sensor TT-01, Temperature Controller TIC-01, and Control Valve CV-2. PID control algorithm is used for the controller as it still represents 98% of all feedback control at over fifty thousand manufacturing facilities around the world (Miller and Desborough, 2000), hence it is the de facto standard in the process control industry. Similarly, the reactor liquid level could be controlled by adjusting the inlet flow rate, using a control loop composed of a level sensor LT-01, Level Controller LIC-01, and Control Valve CV-1. Fig. 3 shows the two control loops using ISA standard symbols (ISA, 1992).

3.1.3. Process safety shutdown

Process hazards are usually identified through a systematic risk assessment process involving hazard studies, e.g., HAZard and OP-

erability (HAZOP) study. High reactor level will lead to reactor overflow. The hazard of the overflow will depend on several factors, including the toxicity of the reactants, the operating temperature of the reactor, and the occupancy level of operators around the reactor area. Similarly, high reactor temperature will lead to exceeding the reactor design temperature and possible reactor damage. Table 1 summarizes these two key hazards for the process and the possible initiating events.

For the Reactor overflow hazard, inlet stream has to be closed. Following IEC 61511 international standard, both the Safety Instrumented Function (SIF) and the control function have to be independent (IEC, 2016). Therefore, the SIF will be composed of an independent level sensor LT-02, a logic solver implementing an interlock function I-1, and a feed inlet shutdown valve XV-1. Upon

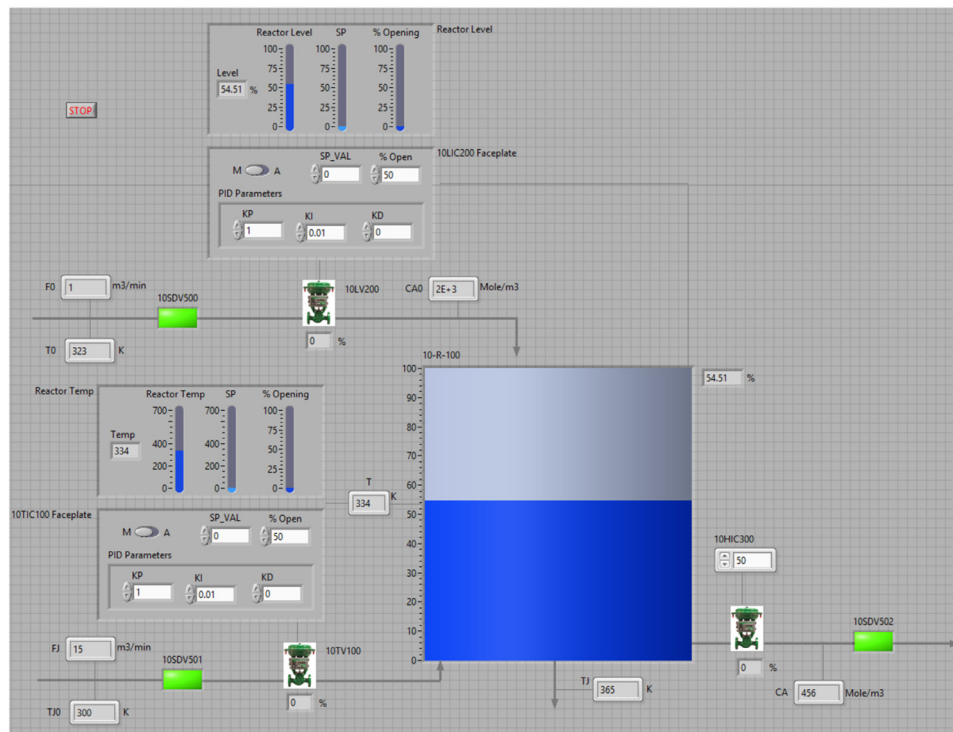


Fig. 2. HMI for the Reactor Process.

Table 1
Partial HAZOP sheet for the reactor process.

Hazard	Initiating Event (Cause)	Consequences	Safeguards (IPL)
High Level (Reactor overflow)	BPCS failure OR Outlet control valve fully closed OR Inlet valve stuck fully open	2 or more fatalities (safety), Product loss (financial), Environmental contamination (environment)	Reactor dike (Mitigation)
High Temperature (Reactor Meltdown/explosion)	Coolant inlet control valve fully (partially) closed OR Inlet valve stuck fully open	10 or more fatalities (safety), Product loss (financial), Environmental contamination (environment)	None

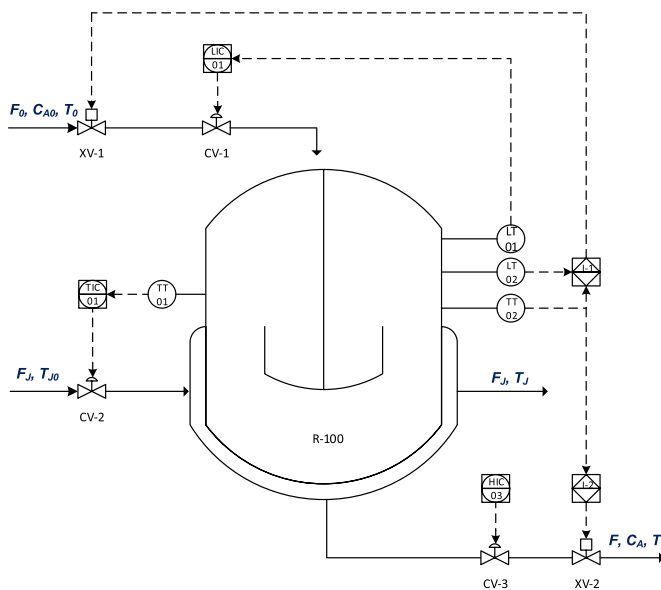


Fig. 3. Reactor P&ID.

detecting a high reactor level, the inlet feed will be stopped via the independent shutdown valve.

For the reactor high temperature hazard, the inlet stream has to be closed. Therefore, the SIF will be composed of an indepen-

dent temperature sensor TT-02, a logic solver implementing an interlock function I-2, and the inlet stream shutdown valve XV-1. In addition, since it is preferred to keep the inventory, a shutdown valve XV-2 is added to the outlet stream. Therefore, upon detecting a high reactor temperature, both the inlet and outlet stream shutdown valves will be closed. These two safety functions are illustrated in Fig. 3.

3.2. Cyber system architecture

Understanding the cyber system architecture is essential for CPS security design. Using the cyber architecture, combined with in-depth knowledge about the physical process dynamics and its associated hazards, a model-based approach could be followed to design an optimal security system for the given CPS according to predetermined optimality criteria, such as the minimization of financial loss or the probability of occurrence of a hazardous event.

Fig. 4 shows the data flow diagram for the testbed. There is a one-way data communication from SIS to BPCS, and HMI does not have direct communication to the SIS as per industrial practice. The HMI has direct communication with BPCS for monitoring and supervisory control actions. Plant data is stored in RT server database, for later on-demand retrieval by the HMI application running on the monitoring workstation and the corporate analysis application running on corporate PCs. As the RT Server has multiple communication links, it will play a key role in attacker penetration from the corporate LAN to the control LAN as detailed in the paper.

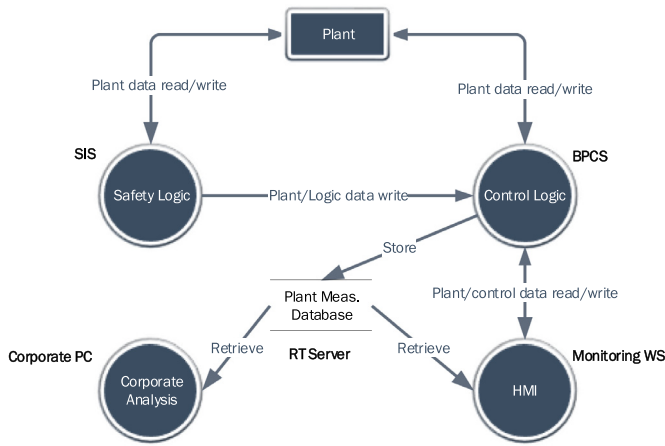


Fig. 4. CPS Testbed Dataflow diagram.

4. Identification of cyber-related hazards

4.1. Hybrid automaton formulation

CPS security attacks distinguish themselves from generic IT system attacks in that the main attacker's goal is to cause damage to the end physical system. Although CPS attacks may have the objective of stealing confidential information that may impact company business, such attacks could be launched on the business LAN level, and does not require the extra effort to penetrate down to the control network. Accordingly, the first natural step to analyze CPS security threats is to identify cyber attacks that are hazard-related. Given the complete process design with control and safety systems, as represented by the P&ID in Fig. 3, it is possible to construct the hybrid system automaton and utilize it to identify the process hazards and the associated cyber-controlled components that *may* be manipulated by an attacker to cause the process hazard.

Hybrid system automaton is a formal model that describes hybrid dynamical systems that have both discrete and continuous dynamics (Raskin, 2005). A simplified mathematical model for the hybrid automaton is represented as a collection $\mathcal{H} = (Q, E, \Sigma, X, \text{Init}, \text{Inv}, \text{Flow}, \text{Jump})$, where Q is a finite set of modes, E is a finite set of event names, $\Sigma: Q \times E \rightarrow Q$ is a transition function representing the discrete changes, X is a set of real-valued variables, Init , Inv , and Flow are functions that define the initial values, constraints, and evolution of the state variables X for each mode, respectively, and finally Jump assigns to each labelled edge a guard condition.

According to the hybrid automaton definition, we can describe the CSTR process by the hybrid automaton in Fig. 5. The set of modes $Q = \{S_0, S_1, \dots, S_7\}$ is defined by the status of the three process streams, namely inlet stream I_s , outlet stream O_s , and cooling jacket stream J_s . The corresponding set of events are $E = \{I_s = 0, I_s = 1, O_s = 0, O_s = 1, J_s = 0, J_s = 1\}$, where a value of zero refers to a closed stream and a value of 1 refers to an open stream. The set of state variables $X = \{L, T, T_j, C_A\}$ describes the reactor level, temperature, coolant temperature, and inlet product mole concentration, respectively. The initial state is S_0 , designating normal reactor operation when all streams are open. The state constraints and evolution are expressed according to the reactor dynamics and omitted for brevity. Finally, the jump describing the guard conditions for each edge is described in terms of respective valve positions.

In addition to the hybrid system automaton, the system is usually constrained to run inside an operating envelope, $\mathcal{E} \subset \mathbb{R}^n$,

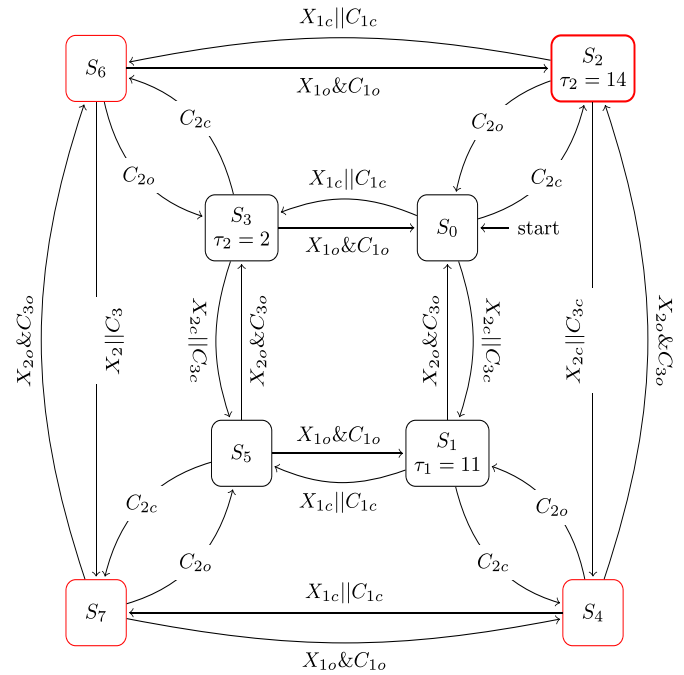


Fig. 5. Reactor hybrid automaton. For transition labels, X refers to a shutdown valve and C refers to a control valve. Subscript 'o' refers to valve status 'open', while 'c' refers to valve status 'closed'. It is assumed that the associated Boolean variable is high when the valve is closed. Reactant stream: $X_1||C_1$, Coolant stream: C_2 , Outlet stream: $X_2||C_3$.

where n is the number of state variables, i.e., $n = |X|$. A system hazard occurs when one or more of the state variables are outside the operating envelope, i.e., $X \notin \mathcal{E}$. This criterion was applied to the CSTR system via simulation to identify the hybrid automaton hazardous states. Four hazardous states were identified, S_2 , S_4 , S_6 , and S_7 . In state S_2 , the coolant stream is closed. The reactor and coolant fluid temperatures exceed the design limit of 550 K after 14 minutes and 23 minutes, respectively, until reaching the thermal equilibrium point $T = T_j = 582$ K via heat exchange after 60 minutes. We define the process hazard time by the minimum time taken by the process to exceed the design limit, therefore $\tau_2 = 14$ min. In state S_4 , the outlet and coolant streams are closed. If the coolant steam is closed first, then the system will transition through state S_2 and the reactor will stabilize at the unsafe temperature $T = T_j = 582$. State S_6 , where the inlet and coolant streams are closed, and state S_7 , where the reactor is completely isolated, are similar to state S_4 . In summary, the reactor will be subject to a high temperature beyond the design limit in all hazardous states, potentially leading to reactor runaway. Hazardous states are designated in Fig. 5 by the red border lines.

Given the hybrid automaton $\mathcal{H}$ of the system with the designated hazardous states, we can extract the hazard initiating events. [Algorithm 1](#) presents a formal method to obtain the at-

Algorithm 1: Generation of hazard execution tree.

```

input :  $\mathcal{H}, S_0, \mathbf{S}$ , (Automaton, initial state, hazardous states)
output:  $M$  (Adjacency matrix for the hazard execution tree)
for  $S \in \mathbf{S}$  do
    | ShortestPath( $S_0, S, M$ ) ;
end
return  $M$ ;

```

tack scenarios that potentially cause a process hazard. The input to the algorithm is the hybrid system automaton, designated haz-

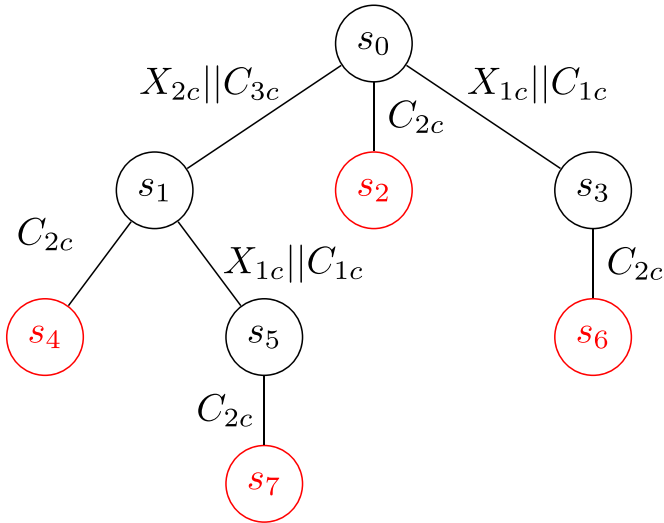


Fig. 6. Hazard execution tree for the CSTR process.

ardous states, and the initial system state s_0 . The algorithm returns the hazard execution tree, where the tree paths are the shortest paths from the initial state s_0 to each hazardous state. These traces are later linked to cyber components that manipulate field devices to cause the process hazard. The algorithm can use any variant of the shortest path algorithm (Thomas H. Cormen, 2009). Algorithm 1 was applied to the CSTR hybrid automaton, and Fig. 6 shows the hazard execution tree output. Hazard states will always be leaf nodes in the hazard tree. Example hazard execution traces are: $s_0 \xrightarrow{C_{2c}} s_2$ and $s_0 \xrightarrow{X_{2c} || C_{3c}} s_1 \xrightarrow{C_{2c}} s_4$.

It should be highlighted that for large systems with a large number of inputs, the number of states of the hybrid automaton may be prohibitively large. One approach to solve this problem is the decomposition of the large system into smaller components, and apply Algorithm 1 to each individual component. In fact, this is the industrial practice when conducting manual hazard analysis by experts, e.g., HAZard and Operability (HAZOP) study (Dunjó et al., 2010). In HAZOP, the system is divided into nodes and each node is studied separately. This approach works well as long as the coupling between system components is captured in the analysis of each individual component.

Fig. 6 shows how a process hazard is generated in terms of process actions, such as opening or closing a valve, but it does not show how these actions could be taken by an attacker. To do so, the cyber architecture of the CPS is required. From the cyber architecture, the cyber components that are linked to process actions could be identified along with their associated vulnerabilities that could be exploited to launch the cyber attacks. Once vulnerabilities are identified, attack trees could be used for threat modeling (Mauw and Oostdijk, 2005).

In order to convert the hazard tree into an attack tree, we need a mapping from process actions to cyber component actions. From Figs. 1 and 3, the control valves are connected to the BPCS while the shutdown valves are connected to the SIS. We designate a relevant valve action using the terminology $\langle \text{System} \rangle \langle \text{Valve_tag} \rangle \langle \text{Action} \rangle$, with system values being B for BPCS and S for SIS, and action values being 'C' for Close and 'O' for Open. Therefore, $B(C_{2_C})$ refers to closing valve C_2 via BPCS relevant vulnerability exploitation. Fig. 7 shows a partial abstract attack tree generated from the hazard tree in Fig. 6 using the introduced terminology.

From the attack tree, it is evident that $B(C_{2_C})$, i.e., closure of valve C_2 via BPCS vulnerability exploitation, is sufficient to cause

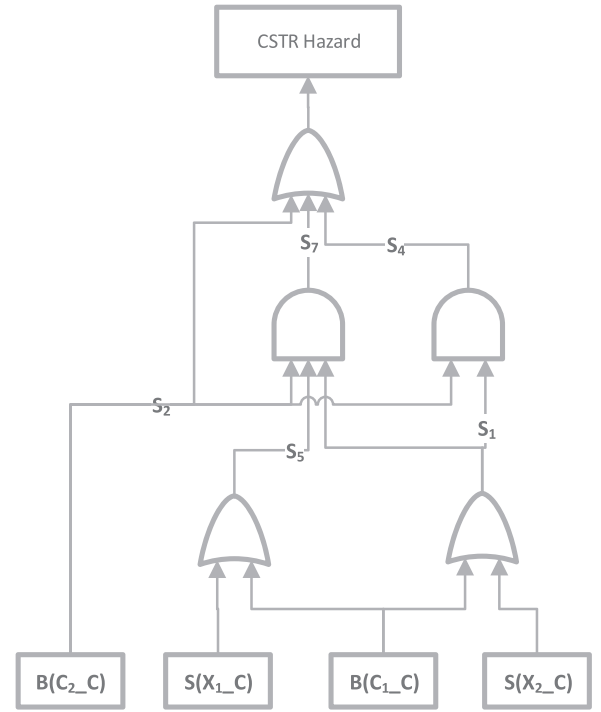


Fig. 7. Partial attack tree for the CSTR hazard tree in Fig. 6.

a reactor hazard. Therefore, in the next section we focus on the compromise of the BPCS to cause a process hazard. It should be highlighted that in general, it may be required to take multiple actions by different cyber components to achieve a process hazard. The CSTR process is a special case in the sense that the closure of C_2 is necessary, and sufficient, to cause a process hazard.

4.2. Hybrid automaton expressiveness

The analysis shows that the hybrid system automaton is a rich diagram, where important information could be inferred. First, a hazard execution tree could be generated, where hazard states are identified and execution traces that lead to process hazards along with the associated actions could be extracted. Second, the time it takes the process to produce a hazard is labeled inside the hazardous state, enabling an accurate assessment of the required response time. Finally, different ways to take the process out of the hazardous state before the time to hazard elapses could be inferred from the outward transitions, noting that the system could return to the previous state by reversing the transition action (e.g., opening a valve that was closed). Therefore, it is possible to identify the physical countermeasures in order to protect the process in case of an attack.

5. Design of cyber attacks

Fig. 7 illustrates the fact that valve $CV-2$ closure via BPCS is a necessary and sufficient cause for reactor hazard. Therefore, this section focuses on the design of cyber attacks for BPCS to cause the desired valve closure, either by integrity or DoS attacks.

From the CPS architecture, the attack entry point is the corporate PC. This could represent an insider attack, using a personal laptop or a corporate PC, or an outside attacker over the Internet who compromised a corporate PC. The mechanism by which the outside attacker could gain access to the corporate PC either locally or remotely via a remote session has been studied extensively in the IT Security literature and will not be treated in the

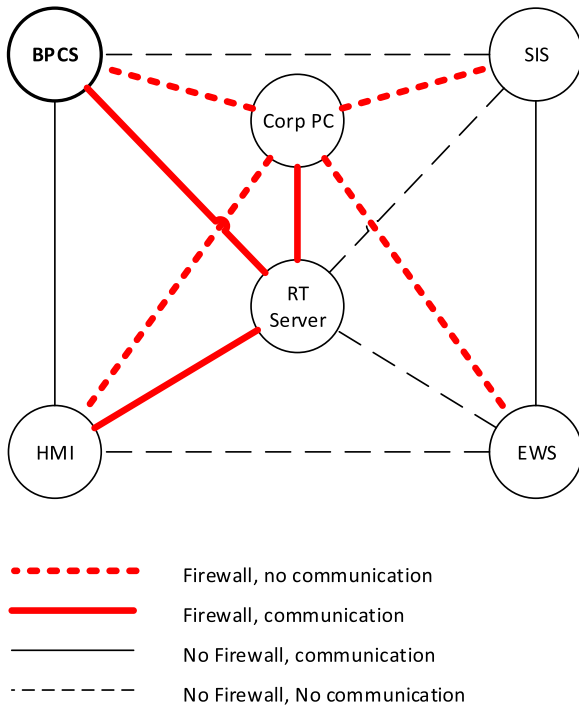


Fig. 8. BPCS connectivity graph. Different line styles designate different connectivity patterns and hence the difficulty of attacks. Only one DMZ server is shown.

paper. For further details about IT security vulnerabilities, refer to [Stallings and Brown \(2018\)](#). In the rest of the paper, we will assume the attacker has a full privileged access to a corporate PC, but not to the control network.

Connectivity Graph: CV-2 is part of a temperature control loop that stabilizes the reactor temperature. The full control loop, including process I/O communication and the PID controller, is implemented on the BPCS. The compromise of CV-2 thus could be achieved by compromising the BPCS itself or any of its connected cyber components to act as a pivot. [Fig. 8](#) shows the connectivity graph for the BPCS, constructed from the CPS architecture and the data flow graph in [Figs. 1](#) and [4](#), respectively. The number of all possible paths between the corporate PC and the BPCS target grows exponentially with the graph size. However, given that most paths are very unlikely due to the inherent difficulty, e.g., the presence of a firewall or absence of any data communication between the connected nodes, we exclude paths that have a firewall and lack data communication between nodes. The probability of a cyber attack across these excluded paths will be insignificant and their impact on the risk assessment process could be neglected. It should be highlighted that for typical CPS networks, the number of nodes is small so the extraction of all possible paths is still feasible, although computationally expensive.

[Fig. 9](#) shows the attack tree that enumerates the likely paths to compromise the reactor process starting from the corporate PC. The root of the tree represents the cyber attack objective of closing valve CV₂, which is the leaf node in the abstract attack tree in [Fig. 7](#). The basic events in the tree in [Fig. 9](#) are modeled using detailed attack trees in this section.

In the following, vulnerability scanning tools were used to identify vulnerabilities and to design cyber attacks for the identified nodes in [Fig. 9](#), namely Real time server, BPCS, and HMI. Whether the vulnerabilities are exploitable is verified by penetration testing. Client-side attacks, such as phishing emails, are not considered for the BPCS, as it is an embedded unattended node (no direct HMI attached), and for the HMI, as it is not an industrial practice to

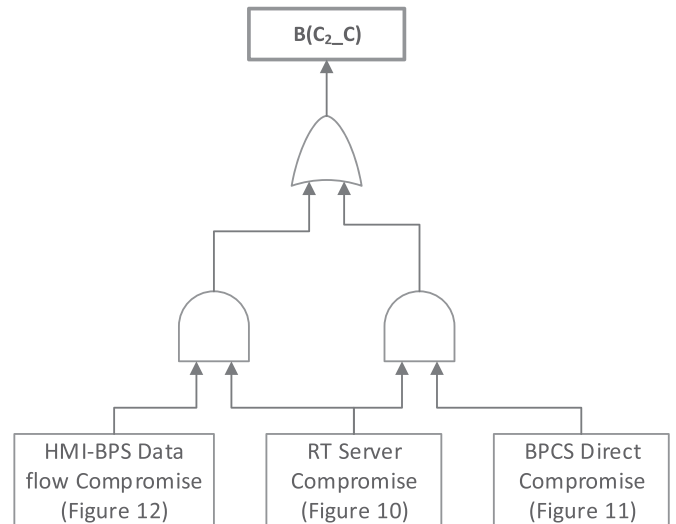


Fig. 9. Reactor Runaway Abstract Attack Tree. Attack scenarios are sequential, starting from RT server compromise, e.g., RT server compromise followed by a BPCS compromise represents one attack scenario.

run any internet application such as a browser or email client on the HMI. [Table 10](#) in the appendix summarizes the tools and commands used.

5.1. Design of RT server cyber attacks

We start from the compromised corporate PC that has legitimate access to the Real Time (RT) server for data logging purposes. Using nmap port scanning command against RT server, we get the information reported in [Table 2](#) for mysql server and ssh services. Mysql could be exploited in different ways including authentication bypass, password hash dump, and brute-force login, depending on the specific server settings. [Fig. 10](#) shows an attack tree to compromise the RT server by escalating the attacker privileges via mysql exploitation.

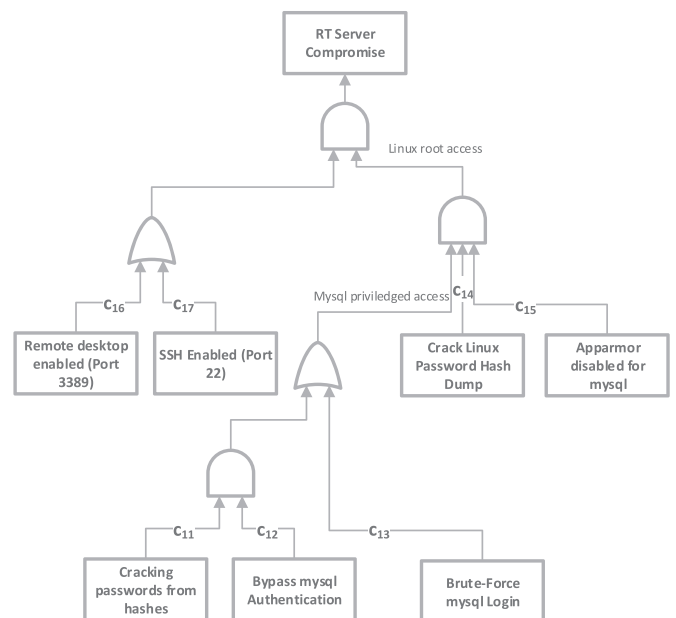


Fig. 10. RT Server Attack Tree.

Table 2
RT Server vulnerabilities - nmap scan.

Port	State	Service	Version	Vulnerabilities
3306/tcp	open	sql	5.7.28, Protocol 10	Authentication bypass, passwords dump, Brute force passwords
22/tcp	open	ssh	OpenSSH 7.9p1 Ubuntu 10	

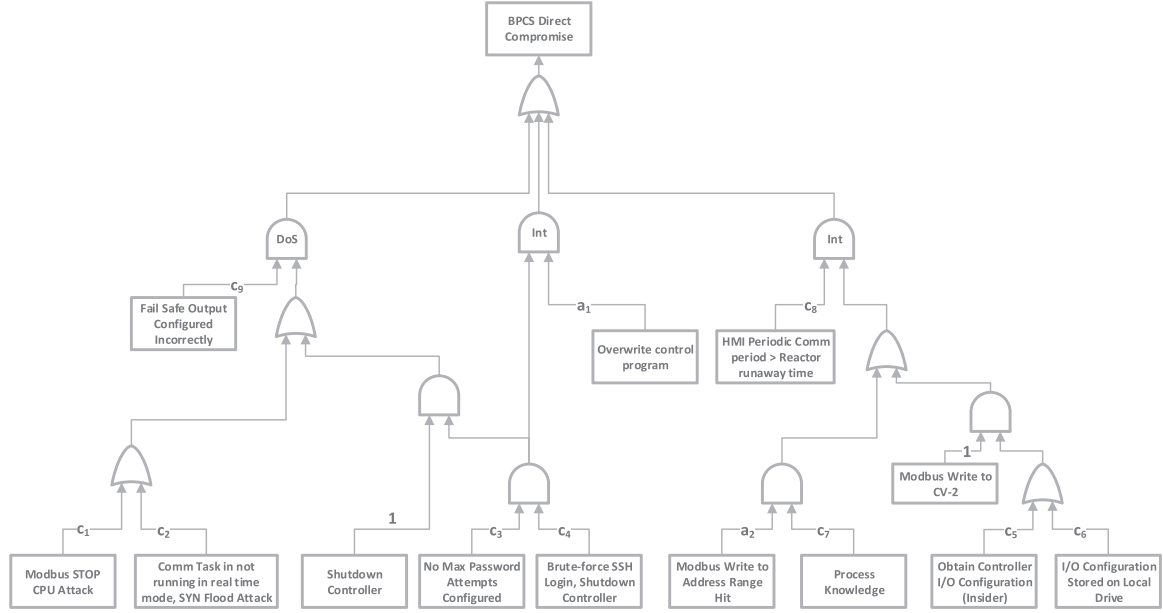


Fig. 11. BPCS Attack Tree. Probabilities related to the corporation are designated by c_i and to the attacker by a_i .

Table 3
BPCS Vulnerabilities - nmap scan.

Port	State	Service	Version	Vulnerabilities
22/tcp	open	ssh	OpenSSH 7.4	Brute-force SSH login
502/tcp	open	mdps	Modbus/TCP	Modbus Write, Stop, MITM

From the attack tree, the probability of RT Server compromise could be approximated by:

$$P[\text{Srv-Comp}] = c_{14}c_{15}(c_{16} + c_{17})(c_{11}c_{12} + c_{13}) \quad (1)$$

Penetration testing would assist in assigning probability measures to the success of each attack action.

5.2. Design of BPCS cyber attacks

Using nmap port scanning tool, Table 3 lists the open ports and associated listening services and service version. In addition, nmap identified the target as NI cRIO 9049 running RT Linux OS. There are many other open ports reported that are used for vendor-specific services, which could be exploited with proper knowledge about vendor hardware and software. We limit our discussion to known services only to keep the treatment general.

According to open ports and services, Fig. 11 shows the BPCS attack tree. Port 502 listens to Modbus communication, so a Modbus malicious write attack, with and without a specific register address, is considered. Information about register addresses could be obtained from controller configuration data, either as a hard copy or stored on local controller drive. Lack of a specific register address for valve CV-2 will require writing to an address range, which may lead to a random valve configuration that won't cause a reactor hazard, e.g., closing all inlet and outlet valves. To increase the probability of success of such an attack, process knowledge is re-

quired. Further, Modbus write attack will not be successful unless no other Modbus master is writing to the same register. For the given testbed, HMI can write to valve registers after setting process controllers to manual mode. This requires that the reactor hazard time is less than the HMI-BPCS (a)periodic communication rate.

With SSH port open, another possible attack is Brute-force SSH login attempt to guess admin password and gain privileged access to the BPCS. This attack will succeed only if the SSH server is configured with no maximum number of password attempts. After gaining the required privileged access, BPCS controller could be shutdown to cause DoS attack, or the control problem could be overwritten to cause integrity attack, assuming the attacker has sufficient knowledge about the hardware as well as the necessary software tools.

Finally, A DoS attack could also be designed by exploiting Modbus STOP CPU function or by using SYN Flood attack against the Modbus or SSH open ports. This later attack will be successful only if the BPCS controller schedule is not a real time scheduler that will give priority to control tasks. It should be noted that DoS attack will not succeed in causing a reactor hazard if process outputs are configured as fail-safe. In such case, the controller will automatically write the pre-configured safe value to process valves in case of controller software crash.

From the BPCS attack tree, the probability of BPCS direct compromise could be approximated by:

$$P[\text{BPCS-Comp}] = c_9[c_3c_4 + (c_1 + c_2)] + a_1c_3c_4 + c_8[a_2c_7 + (c_5 + c_6)] \quad (2)$$

5.3. Design of HMI-BPCS data flow attacks

In this attack vector, HMI has to be compromised first to mount the malicious data over the HMI-BPCS data flow stream. Table 4

Table 4
HMI Vulnerabilities - nmap scan.

Port	State	Service	Version	Vulnerabilities
502/tcp	open	mdps	Modbus/TCP	Modbus write, stop
3306/tcp	open	mysql	MySQL	
3389/tcp	open	rdp		

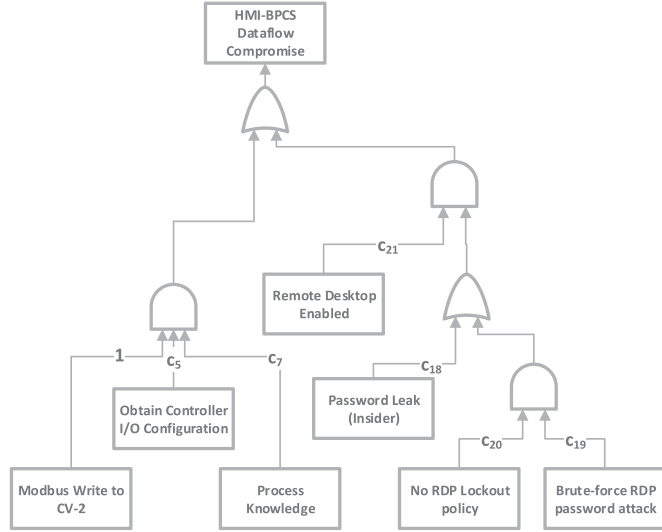


Fig. 12. HMI-BPCS Dataflow Attack Tree.

shows the nmap scan results for the HMI. The machine is running Windows 10 and fully patched, therefore very few vulnerabilities were detected. Mysql service is running to communicate with the RT Server for real time data and trend display for the operator. Modbus master service is running to poll and write data to the BPCS controller. Remote desktop is turned on to grant different operators access to HMI machines for other plant zones.

Fig. 12 shows the HMI attack tree. Remote desktop is exploited using either brute-force password attack or via password leak. In addition, Modbus open port is exploited to write malicious values to relevant registers, provided process and I/O configuration knowledge are available. Since HMI has mysql client connection to RT Server, mysql client side attacks could be considered as well. However, given the low number of mysql client side vulnerabilities and the difficulty associated, we ignored mysql client side attacks in the penetration testing.

From the HMI attack tree, the probability of HMI-BPCS dataflow compromise could be approximated by:

$$P[\text{HMI-BPCS}] = c_5 c_7 + c_{21} (c_{18} + c_{19} c_{20}) \quad (3)$$

It should be highlighted that the presented attacks are not meant to be comprehensive. As an example, we did not consider Man In The Middle (MITM) attacks as the compromised RT server is behind a firewall, hence it cannot monitor the traffic or cause ARP poisoning unless one node on the control network is compromised. Also, we assume perfect security around the company premises, which does not allow for direct physical access to hardware. Finally, we assume the IT security policy does not allow the plug in of foreign USB devices to plant control equipment. Should any of these assumptions be violated, the attack trees have to be expanded to accommodate for these new threats. Moreover, the design of the cyber attacks does not include day zero attacks, which are unknown at design time and could only be detected online using anomaly detection techniques (AlEroud and Karabatis, 2012).

6. Penetration testing and risk assessment

Penetration testing was carried out according to the attack trees designed in Section 5 to verify the identified vulnerabilities and support the risk assessment process by quantifying the probability of success of different attack actions.

6.1. RT Server

Table 5 summarizes the penetration testing results for the attack tree in Fig. 10. Bypass mysql authentication attack failed due to enforced authentication configuration. Brute-force mysql login attack succeeded to obtain mysql weak root password "sql2563". With mysql root password, Linux password hash file was loaded successfully into mysql using LOAD_FILE command and dumped for password cracking. Finally, Linux hashed password for root was recovered. The RT server is now under full control using root password and either SSH or remote desktop login. Attack injection is semi-automated using Metasploit modules.

From penetration testing results, it can be safely assumed that mysql login authentication is enforced, especially for industrial plants, therefore $c_{12} = 0$. In addition, we can assume that only one remote access capability is allowed, either remote desktop or SSH, for operational purposes. We arbitrarily choose SSH hence $c_{16} = 0$. Therefore, the probability of RT Server compromise reduces to:

$$P[\text{Srv-Comp}] = c_{13} c_{14} c_{15} c_{17} \quad (4)$$

The probability of such an sql attack could be made zero by either closing the SSH port or enabling OS security on mysql database. Both options may not be possible for operational purposes. However, the probability could be made arbitrarily small by enforcing strong password policy for both mysql database and Linux server. It should be noted, however, that the enforcement of a very strong password policy may lead to difficult passwords to remember, hence written down passwords that may be leaked.

6.2. BPCS

Table 6 summarizes the penetration testing results for the attack tree in Fig. 11. Modbus STOP attack failed as it is not supported by the controller Modbus implementation. SYN flood attack did not also work because the BPCS controller runs RT Linux OS, which gives minimum guarantees on the control algorithm task periodicity. The Brute-force SSH login attack was successful in acquiring the root password, but unsuccessful in causing a DoS attack as the fail safe output is correctly configured on the controller. However, with controller root password, it is possible to overwrite the control program with malicious code and cause integrity attack. Modbus write attack was successful in writing the required value to the pre-determined register but the written value did not persist due to the periodic HMI-BPCS communication that continuously writes to the same register. Finally, random write to a contiguous address range was unsuccessful to cause a hazard without sufficient knowledge about the output-register mapping.

From the penetration testing results, we can make some simplifying assumptions to the attack tree probabilities. The probability of incorrect configuration for fail safe output could be set to 0, assuming the configuration is made once per controller software lifetime (we ignore here the possibility of a human error during controller reprogramming). Also, the probability that a random Modbus write would result in a hazard is very small given the large number of registers typically used in an industrial setup, so $a_2 = 0$. Finally, strong password policy enforcement decreases the probability of a successful brute force SSH attack significantly,

Table 5
Real Time Server Penetration Testing Results.

Vulnerability	Exploit Tool	Exploit Result	Notes
Bypass mysql Authentication	Metasploit	Fail	mysql server configured to enforce authentication
Brute-force mysql login	Metasploit	Success	Weak mysql root password used
Linux password hash dump	Metasploit	Success	Apparmor disabled for mysql
Crack Linux hashed passwords	Metasploit	Success	root password recovered

Table 6
BPCS Penetration Testing Results.

Vulnerability	Exploit Tool	Exploit Result	Hazard Caused	Notes
Modbus STOP CPU Attack	Metasploit	Fail	No	Function not supported by BPCS Modbus implementation
SYN Flood Attack to ports 22, 502	Metasploit	Fail	No	RTOS does not degrade control algorithm performance with communication spikes
Brute-force SSH login	Metasploit	Success	Y/N	user: admin, pass: "nirroot" successfully deduced. DoS attack was unsuccessful due to fail safe setting. Integrity attack succeeded with proper software tools
Modbus write to contiguous address range	Metasploit	Success	No	Random write to Modbus registers did not cause a process hazard
Modbus write to a specific register	Metasploit	Success	No	HMI has periodic communication with BPCS that overwrites written data every 5 sec.

Table 7
HMI Penetration Testing Results.

Vulnerability	Exploit Tool	Exploit Result	Hazard Caused	Notes
Brute-force RDP login	Hydra	Success	Yes	user: admin, pass: "reactorws" successfully deduced. HMI access gained
Modbus write to contiguous address range	Metasploit	Success	Yes	Process and Modbus configuration knowledge assumed

hence $c_4 = 0$. Accordingly, the probability of BPCS compromise reduces to:

$$P[\text{BPCS-Comp}] = c_8(c_5 + c_6) \quad (5)$$

6.3. HMI

Table 7 summarizes the penetration testing results for the attack tree in Fig. 12. RDP brute-force password attack was successful with user: operator and password: "reactorws". Such passwords are not uncommon in industrial plants as often times there is a repeated naming convention used, which is composed of plant unit name and WS for WorkStation. With remote access granted, access to HMI to switch reactor controller to manual mode and close the coolant valve was possible. The Modbus attack was also successful in writing to Modbus registers at the HMI. However, the period of writing data has to be much shorter than both the Modbus poll delay between the HMI and BPCS and the GUI-Modbus registers writing loop frequency. This is mainly to avoid malicious data overwrite. This later Modbus attack assumes sufficient process knowledge and Modbus configuration data.

One finding from penetration testing that could simplify the probability of HMI-BPCS compromise in (3) is that RDP lockout policy is an easy fix that could be configured in Windows 10 settings. Therefore, setting $c_{20} = 0$ in (3) we get:

$$P[\text{HMI-BPCS}] = c_5c_7 + c_{18}c_{21} \quad (6)$$

6.4. Overall risk assessment

To assess the overall risk, a formula for risk scoring in terms of pre-defined risk metrics is required. This formula usually gives different weights for different risk metrics according to the organizational policy. The two key metrics in any risk assessment are the threat likelihood, L , and the cost of the consequences, q . In industry, and to simplify the analysis, the risk scoring function is usually categorical, using *risk ranking* tables. The risk ranking table is

on a matrix form where the rows represent finite likelihood categories and the columns represent finite consequence categories. The row-column intersection represent the risk rank, e.g., No, Low, Medium, and High risk. According to the risk rank, a Target Mitigated Event Likelihood (TMEL) is defined. If the event likelihood is $> \text{TMEL}$, then an additional protection layer is required to reduce the likelihood to the TMEL. More information on Layer Of Protection Analysis (LOPA) could be found in IEC (2016).

In this work, we adopt a continuous (rather than categorical) function that directly calculates the risk score. We define four risk metrics: Likelihood L , and three consequences; Safety loss S , Financial loss F , and Environmental loss E . We designate the target corporation risk score to be r . We define q to be the normalized cost given by:

$$q = \alpha \left(\frac{S}{S_m} \right) + \beta \left(\frac{F}{F_m} \right) + \gamma \left(\frac{E}{E_m} \right) \quad (7)$$

$$1 = \alpha + \beta + \gamma$$

S_m , F_m , E_m are normalization factors representing the maximum value set for each relevant category, and α , β and γ are weight factors defining the contribution of each metric to the overall risk score, and usually defined by the organization. The total cost Q is a random variable defined on the sample space $\Omega = \{0, 1, 2, \dots\}$ representing the number of hazardous events in a time interval. The best well-known risk score is given by the expected value of the total cost:

$$R = E[Q] = E[qN] = qE[N] = qL \quad (8)$$

where L is the likelihood of the hazardous event in terms of the number of events per time interval. The target risk score r is chosen according to the consequence. We assume the following linear relationship:

$$\log r = -\zeta q \quad (9)$$

Table 8
CPS Security Design Variables and Countermeasures.

Design Variable	Description	Possible Countermeasures	Drawbacks
P_c	Probability of compromising a corporate PC	IT security policy	
c_5	Probability of leaking I/O and Modbus configuration	Non-technical - HR Policy	
c_6	Probability of storing configuration documentation on the controller	Prevent local storage	Local storage is more convenient and guarantees no data loss
c_7	Probability of leaking process information	Non-technical - HR Policy	
c_8	Probability that HMI-BPCS comm. period is greater than reactor hazard time	Very low probability except for small reactors-Increase HMI-BPCS comm. frequency	
c_{13}	Probability of successful brute-force mysql login attack	Enforce strong password policy	Forgetting passwords and writing them down
c_{14}	Probability of successful password recovery from a hash dump	Enforce strong password policy	Forgetting passwords and writing them down
c_{15}	Probability that security monitoring app is disabled for mysql	Increase security armoring for mysql application	Less flexibility in database management and interaction
c_{17}	Probability that SSH is enabled for RT Server	Block remote access	Operational inflexibility and higher operational cost
c_{18}	Probability of leaking operation passwords	Non-technical - HR Policy	
c_{21}	Probability that RDP is enabled for HMI workstations	Disable RDP	Inflexible operational environment and higher HMI configuration cost

where ζ is a proportionality constant. The risk score is given by:

$$R = L \left[\alpha \left(\frac{S}{S_m} \right) + \beta \left(\frac{F}{F_m} \right) + \gamma \left(\frac{E}{E_m} \right) \right] \quad (10)$$

The risk score has to satisfy $R \leq r$. In addition, since the likelihood is usually very small, we adopt the log function for the risk:

$$\log L \leq \log r - \log \left[\alpha \left(\frac{S}{S_m} \right) + \beta \left(\frac{F}{F_m} \right) + \gamma \left(\frac{E}{E_m} \right) \right] \\ = -(\zeta q + \log q) \quad (11)$$

To calculate the likelihood L , we combine (4)–(6) according to the attack tree in Fig. 9. Ignoring higher order probability terms, the probability of reactor runaway is given by:

$$P[\text{Runaway}] = c_{13}c_{14}c_{15}c_{17}[c_8(c_5 + c_6) + c_5c_7 + c_8c_{21}] \quad (12)$$

where, without loss of generality, we assume a unity attack event per the chosen time interval. Assuming the probability that an attacker could compromise a corporate PC is given by P_c , the overall probability of reactor runaway is given by:

$$L = P_c P[\text{Runaway}] \\ = P_c c_{13}c_{14}c_{15}c_{17}[c_8(c_5 + c_6) + c_5c_7 + c_8c_{21}] \quad (13)$$

Combining (11) and (13):

$$P_c c_{13}c_{14}c_{15}c_{17}[c_8(c_5 + c_6) + c_5c_7 + c_8c_{21}] \leq 10^{-(\zeta q + \log q)} \quad (14)$$

Eq. (14) represents the design constraint for CPS security. Table 8 enumerates the design variables with description and possible countermeasures to reduce or eliminate the associated probabilities. It should be highlighted that some vulnerabilities could be entirely eliminated by taking the extreme policy of blocking the relevant services. However, the price paid is less flexibility in asset management and potentially higher cost of ownership.

6.5. Risk assessment results

We apply the risk assessment methodology to the case study presented in the paper. It should be highlighted that the risk assessment methodology works by defining a target tolerable risk level, then working backwards to find an upper bound on the probability of cyber failures for CPS components. This is in comparison to the forward risk assessment process where the risk is assessed for a given system using its actual failure probability figures. The advantage of the backward approach is that it represents a proactive approach that is suitable for design time as well as runtime.

Table 9
Reactor Runaway Risk Scenario - Design Example.

Design Parameter	Description	Value
α	Safety loss weight	0.7
β	Financial loss weight	0.2
γ	Environmental loss weight	0.1
S	Safety loss	10 fatalities
S_m	Maximum safety loss	10 fatalities
F	Financial loss	\$5 M
F_m	Maximum financial loss	\$10 M
E	Environmental loss	\$10, 000
E_m	Maximum environmental loss	\$2 M
ζ	Target risk prop. const	6

Eq. (14) represents the design equation for the system, where the exponent on the right hand side is calculated from (11) using the desired target risk level. All probabilities are considered design variables that need to be specified to achieve the target risk level. To illustrate the process, Table 9 shows an instance of the design parameters and risk target for the reactor runaway risk scenario. The values in Table 9 are used in (7) to yield a normalized cost $q = 0.8005$. With $\zeta = 6$, the target risk score is obtained from (9) as $r \approx 10^{-5}$. With these values, we can substitute in (14) to obtain the relationship between the design variables.

$$P_c c_{13}c_{14}c_{15}c_{17}[c_8(c_5 + c_6) + c_5c_7 + c_8c_{21}] \leq 10^{-5} \quad (15)$$

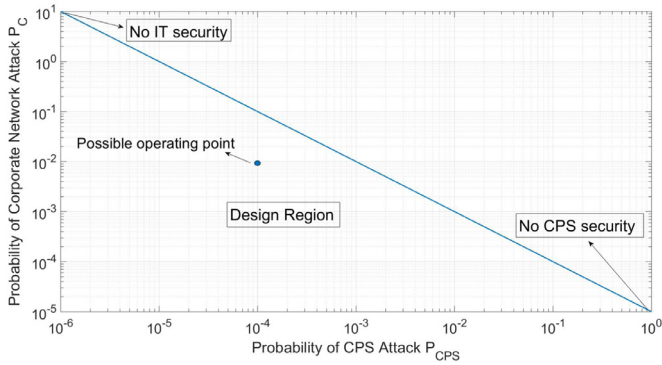
To get more insight into the design process, we make some assumptions regarding design variables. First, we assume that the probability of leaking information is the same whether it is software configuration or process documentation. Therefore, $c_5 = c_7$. Second, we assume the same password policy is enforced for different systems, including OS, database server, and remote desktop connection. Therefore, $c_{13} = c_{14} = c_{18}$. Third, the probability that HMI-BPCS communication period is greater than reactor hazard time is negligibly small for all practical purposes, so $c_8 = 0$. Fourth, since we chose SSH as the only remote configuration tool for the RT server and disabled remote desktop capability, we can set $c_{17} = 1$. Finally, we assume remote desktop is disabled for all operator HMIs despite the operational inconvenience, hence $c_{21} = 0$. This leads to the reduced design equation:

$$\underbrace{(c_5^2 c_{13}^2 c_{15})}_{P_{\text{CPS}}} P_c \leq 10^{-5} \quad (16)$$

where the first term P_{CPS} represents the cyber attack failure probability due to CPS security weaknesses and P_c represents the

Table 10
Vulnerability Scanning and Penetration Testing Commands.

Node	Tool	Module	Purpose	Commands
RT Server	nmap	–	Scan	nmap -p- -sT -sV 192.170.1.2
RT Server	Metasploit	mysql_authbypass_hashdump	Bypass auth.	set RHOSTS 192.170.1.2, set THREADS 50, exploit
RT Server	Metasploit	mysql_login	Brute-force SQL login	set RHOSTS 192.170.1.2, set USERNAME root, set PASS_FILE ./passfile.lst, exploit
BPCS	nmap	–	Scan	nmap -p- -sT -sV 192.168.1.10
BPCS	Metasploit	modicon_command	Controller Remote Start/Stop	set RHOSTS 192.168.1.10, set RPORT 502, set MODE STOP, exploit
BPCS	Metasploit	synflood	BPCS SYN Flood attack	set RHOSTS 192.168.1.10, set RPORT 22, set RPORT 502, exploit
BPCS	Metasploit	ssh_login	Brute-force SSH login	set RHOSTS 192.168.1.10, set USERPASS_FILE ./passfile.list, exploit
BPCS	Metasploit	modbusclient	Write to a single Modbus register	set RHOSTS 192.168.1.10, set RPORT 502, set DATA_ADDRESS 0, set DATA 0, exploit
BPCS	Metasploit	modbusclient	Write to multiple Modbus register	set RHOSTS 192.168.1.10, set RPORT 502, set DATA_ADDRESS 0, set DATA_REGISTERS 0,100,100, exploit
HMI	nmap	–	Scan	nmap -p- -sT -sV 192.168.1.20
HMI	Hydra	–	Brute force RDP	Hydra v f -l operator -P ./passfile.list rdp://192.168.1.20
HMI	Metasploit	modbusclient	Write to multiple Modbus register	set RHOSTS 192.168.1.20, set RPORT 502, set DATA_ADDRESS 0, set DATA_REGISTERS 0,100,100, exploit

**Fig. 13.** Cyber Security Design Curve. Any point in the area under the curve represents a valid design that satisfies the target mitigated risk level.

cyber attack failure probability due to IT security weaknesses. Eq. (16) formalizes the interplay between IT security, as ending at the corporate network level, and CPS security, from the isolating firewall down to the plant floor. Fig. 13 is a log-log plot for (16), where the design space is the area under the curve. Any point outside the design region results in a higher risk level than the tolerable value specified by the corporation. In addition, as one probability increases, the other probability has to decrease to compensate and achieve the target risk level. Examples are the extreme points $(1, 10^{-5})$ and $(10^{-5}, 1)$. In practice, an operating point that represents a compromise between IT security and CPS security should be selected, e.g., $(P_{CPS}, P_C) = (10^{-4}, 10^{-2})$ in Fig. 13. If the design constraint cannot be achieved, then a process modification, e.g., a safety instrumented function, needs to be added. This example shows the interplay between security and safety assessment, and that they cannot be carried out sequentially, but rather in an integrated way. This is one of the main insights gained from this work, which is further discussed in Section 7.

6.6. Hazard mitigation

The purpose of the risk assessment and countermeasure design is to minimize the probability of an attack that would cause a process hazard to the target mitigated likelihood. However, there is still a probability that an attack will be launched that cause a pro-

cess hazard. In such case, a hazard mitigation strategy is mandatory.

One of the advantageous of the process hybrid automaton in Fig. 5 is that it shows the best course of action when being in a hazardous state. The guard conditions on the outward transitions identify the process manipulation required to get out of the hazardous state. As an example, If the current process state is S_4 , and a hazard is developed, then opening valve CV-2 will cause a transition to the safe state S_1 . However, two key questions are in order: (1) how the current process state could be estimated?, and how can we take an action if the cyber system is compromised? The first question concerns the problem of state estimation in hybrid systems which has been studied extensively in the literature (Prakash et al., 2010). To answer the second question, taking an action with a compromised cyber system has one of two ways; either having a backup image of the whole system that could be restored, or diagnosing the system online to isolate the attack and gaining control over the CPS. In both cases, the time taken to implement the mitigation action, τ_m , should satisfy:

$$\tau_m < \tau_p + \tau_s - \tau_d \quad (17)$$

where τ_s is the time the system can operate outside its safe operating envelope with no damage and τ_d is the time taken to detect the hazard and τ_p is the process hazard development time, as reported in the system hybrid automaton. If this condition is not satisfied, e.g., covert attack that misleads the operator via malicious HMI data and resulting in high detection time τ_d , then a process hazard will take place, and the mitigation action may or may not reduce the damage according to the process design. In such cases, a non-cyber (usually mechanical) mitigating solution has to be implemented in the process. For the reactor system, control valve CV-2 could have a manual override in the field to open or close it by a manual action.

7. Discussion

The design and analysis process as applied to the case study in this paper could be generalized as in Fig. 14, where the physical process is included in the design cycle and hence subject to several iterations. A truly integrated approach to design both the safety and security systems should include both the physical and cyber systems at early stages of the design process.

The physical process modeling using hybrid automaton revealed several important insights. First, careful process modeling is cru-

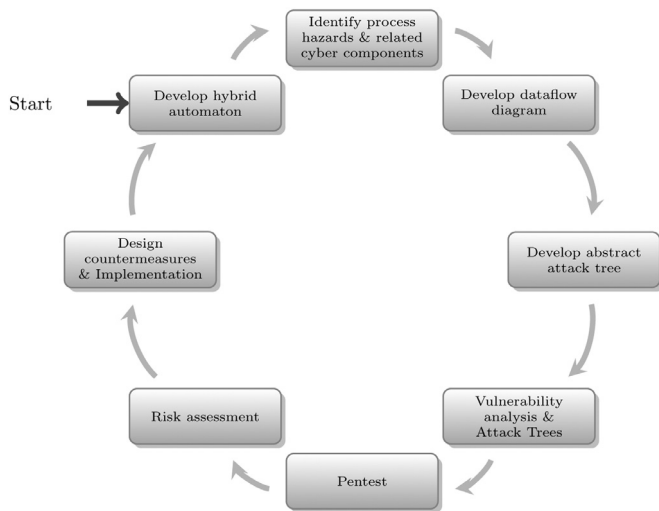


Fig. 14. Model-Based Design Cycle, as followed in the case study.

cial to identify the true hazards and associated cyber components to design a fit-for-purpose security system. Second, the time to develop a process hazard is an important parameter that should be taken into account during risk assessment and mitigation design. Along with the detection system, this may lead to more cost-effective cyber designs. Finally, as hazard generation is dependent on both the sequence of attack and time spent in each state, combining the attack traces from the hybrid automaton with the attacker probabilistic model results in more accurate risk assessment.

There is a tight coupling between safety and security, in terms of their impact on the physical system. Designing both systems independently may not lead to an optimal design. As the case study shows, only one physical component and two cyber nodes are the most critical components. All other components play a secondary role.

The model-based design approach followed in this work, where physical system modeling, data flow modeling, and attack trees are integrated provides one unified framework to design safe and secure CPS. The adoption of this integrated approach in industry is contingent on the development of software tools that automate most of the tasks that have been carried out manually in this work. This includes model development, hazard identification, data flow graph development, vulnerability scanning, attack tree development, penetration testing, and countermeasure design. Although several tools exist to automate individual tasks, an integrated tool that defines and implements the interface between different tasks is necessary.

The value of working backwards by identifying first the process hazards, though reducing significantly the number of attack scenarios, may not be readily obvious in centralized architectures. For example, the work presented shows that valve CV-2 is the sole critical component, and therefore, BPCS and HMI are the cyber components that should be protected. However, BPCS is the main process controller that implements all control algorithms, so the identification of CV-2 did not lead to effort or cost savings as the whole BPCS will be hardened anyway. For centralized systems like the CPS presented in this paper, this may lead to program segmentation and special protection for CV-2 related software modules. However, the significant value of this approach is revealed when considering distributed systems, where smart sensors and actuators are embedded devices that implement their own software and communicate over a common bus, without a need for a centralized controller.

Finally, it should be highlighted that the presented model-based design approach works for both offline and online risk assessment.

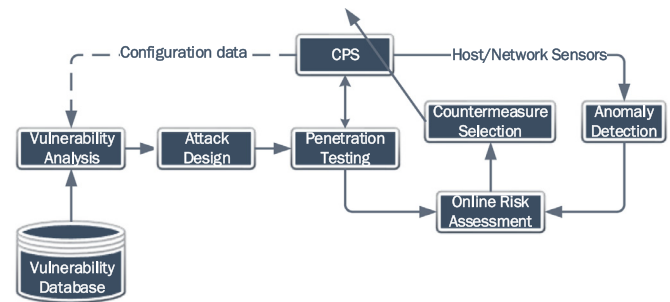


Fig. 15. Model-Based risk assessment with day zero attacks.

However, for online risk assessment, it is also desirable to detect day zero attacks that are not available in vulnerability databases. In such case, the presented framework needs to be augmented with online anomaly detection to perform a complete risk assessment. The architecture of this solution is shown in Fig. 15, including the possible countermeasure design. Fig. 15 represents a natural extension to the work presented in this paper.

8. Conclusion and future work

In this paper, we pursued an integrated approach to design the security system of a given CPS. The key finding is that by exploring the physical system behavior, it was observed that not all attacks could cause a system hazard, a hazard may take time to develop, and it may be possible to nullify the attack effect. Therefore, the paper highlights the need for an integrated approach to design the safety and security systems. Model-based design is a cornerstone for this integrated approach to be successful. For successful industrial adoption, a design automation tool chain that integrates physical and cyber domain modeling, as well as attack modeling and penetration testing, needs to be developed.

Several research directions could be identified from this work. First, the attacker profile was ignored in the risk assessment (all probabilities were assumed to be 1, certain events). This may lead to non-optimal system designs. Attackers possess different knowledge and skill set, and this needs to be captured in the risk assessment process. In addition, the probability that a process hazard may not be produced even though a process upset is caused due to random attacker actions was not considered. This factor may significantly decrease the overall likelihood of a process hazard post a cyber attack. Second, most successful attacks in the CPS domain are covert attacks that deceive the user via concurrent HMI manipulation. These attacks have complex structures and multiple objectives that need to be studied in more depth. Third, cyber attacks may lead to a system malfunction, and therefore should be included in the safety risk assessment as an initiating cause. This may lead to a reformulation of the current industrial practice for hazard identification and protection studies. Finally, when simulating the physical process for different cyber attack actions, it was assumed that the system disturbances are within operating limits. This assumption may be violated if the attack is organized against multiple system units simultaneously, resulting in the system being subject to concurrent disturbances and a cyber attack. The study of the composition of component risk assessment to yield an overall system risk assessment measure is an interesting research direction. Finally, the risk assessment process presented in this work is model-based, hence relying on known vulnerabilities and attack scenarios. However, day zero attacks represent a significant threat and challenge to CPS security. The integration of the model-based approach and machine learning approaches used for day zero attack detection in the context of online risk assessment is an important future research direction.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRediT authorship contribution statement

Ashraf Tantawy: Conceptualization, Methodology, Software, Investigation, Validation. **Sherif Abdelwahed:** Conceptualization, Writing - original draft. **Abdelkarim Erradi:** Conceptualization, Writing - review & editing. **Khaled Shaban:** Supervision, Writing - review & editing.

Acknowledgment

This research was made possible by NPRP 9-005-1-002 grant from the Qatar National Research Fund (a member of The Qatar Foundation). The statements made herein are solely the responsibility of the authors.

References

- Abdo, H., Kaouk, M., Flaus, J.M., Masse, F., 2018. A safety/security risk analysis approach of industrial control systems: a cyber bowtie combining new version of attack tree with bowtie analysis. *Computers and Security* 72, 175–195. doi:10.1016/j.cose.2017.09.004.
- Alcaraz, C., Zeadally, S., 2015. Critical infrastructure protection: requirements and challenges for the 21st century. *Int. J. Crit. Infrastruct. Prot.* 8, 53–66. doi:10.1016/j.ijcip.2014.12.002.
- AlEroud, A., Karabatis, G., 2012. A contextual anomaly detection approach to discover zero-day attacks. In: 2012 International Conference on Cyber Security. IEEE, pp. 40–45.
- Ashibani, Y., Mahmoud, Q.H., 2017. Cyber physical systems security: analysis, challenges and solutions. *Computers & Security* 68, 81–97. doi:10.1016/j.cose.2017.04.005.
- Ashraf, T., Sherif, A., Chen, Q., 2019. Continuous stirred tank reactors: modeling and simulation for CPS security assessment. In: The International Conference on Computational Intelligence and Communication Networks, CICON 2019.
- Cherdantseva, Y., Burnap, P., Blyth, A., Eden, P., Jones, K., Soulsby, H., Stoddart, K., 2016. A review of cyber security risk assessment methods for SCADA systems. *Computers & Security* 56, 1–27. doi:10.1016/j.cose.2015.09.009.
- Craig, P.A., 2008. Metrics for the National SCADA Test Bed Program. Pacific Northwest National Lab.(PNNL), Richland, WA.
- Dunjó, J., Fthenakis, V., Vilchez, J.A., Arnaldos, J., 2010. Hazard and operability (hazop) analysis. a literature review. *J. Hazard. Mater.* 173 (1–3), 19–32.
- Durand, H., 2018. A nonlinear systems framework for cyberattack prevention for chemical process control systems. *Mathematics* 6 (9), 169.
- Friedberg, I., McLaughlin, K., Smith, P., Laverty, D., Sezer, S., 2017. STPA-SafeSec: safety and security analysis for cyber-physical systems. *J. Inf. Secur. Appl.* 34, 183–196. doi:10.1016/j.jisa.2016.05.008.
- Genge, B., Haller, P., Enachescu, C., 2019. Anomaly detection in aging industrial internet of things. *IEEE Access* 7, 74217–74230. doi:10.1109/ACCESS.2019.2920699.
- Guan, Y., Ge, X., 2018. Distributed attack detection and secure estimation of networked cyber-Physical systems against false data injection attacks and jamming attacks. *IEEE Trans. Signal Inf. Process. Networks* 4 (1), 48–59. doi:10.1109/TSIPN.2017.2749959.
- Hahn, A., Ashok, A., Sridhar, S., Govindarasu, M., 2013. Cyber-physical security testbeds: architecture, application, and evaluation for smart grid. *IEEE Trans. Smart Grid* 4 (2), 847–855. doi:10.1109/TSG.2012.2226919.
- Huang, S., Zhou, C.J., Yang, S.H., Qin, Y.Q., 2015. Cyber-physical system security for networked industrial processes. *Int. J. Autom. Comput.* 12 (6), 567–578. doi:10.1007/s11633-015-0923-9.
- IEC, 2016. IEC 61511-1:2016, Functional safety - Safety instrumented systems for the process industry sector - Part 1: Framework, Definitions, System, Hardware and Application Programming Requirements. Technical Report. IEC.
- Inl, T., Idaho National Laboratory, 2009. National SCADA Test Bed Substation Automation Evaluation Report. Technical Report. 10.2172/968658
- ISA, 1992. ANSI/ISA-5.1-1992, Instrumentation Symbols and Identification. Technical Report.
- Januario, F.P., Leitão, J., Cardoso, A., Gil, P., 2017. Resilience enhancement in cyber-physical systems: amultiagent-based framework. *Multi-agent Syst.* 185.
- Jarmakiewicz, J., Parobczak, K., Maślanka, K., 2017. Cybersecurity protection for power grid control infrastructures. *Int. J. Crit. Infrastruct. Prot.* 18, 20–33. doi:10.1016/j.ijcip.2017.07.002.
- Ji, X., Yu, H., Fan, G., Fu, W., 2016. Attack-defense trees based cyber security analysis for CPSS. In: 2016 IEEE/ACIS 17th International Conference on Software Engineering, Artificial Intelligence, Networking and Parallel/Distributed Computing, SNPD 2016. IEEE, pp. 693–698. doi:10.1109/SNPD.2016.7515980.
- Kanamaru, H., 2017. Bridging functional safety and cyber security of SIS/SCS. In: 2017 56th Annual Conference of the Society of Instrument and Control Engineers of Japan, SICE 2017. IEEE, pp. 279–284. doi:10.23919/SICE.2017.8105699.
- Koutsoukos, X., Karsai, G., Laszka, A., Neema, H., Potteiger, B., Volgyesi, P., Vorobeychik, Y., Sztipanovits, J., 2017. Sure: a modeling and simulation integration platform for evaluation of secure and resilient cyber-physical systems. *Proc. IEEE* 106 (1), 93–112.
- Mathur, A.P., Tippenhauer, N.O., 2016. SWaT: a water treatment testbed for research and training on ICS security. In: 2016 International Workshop on Cyber-physical Systems for Smart Water Networks (CySWater). IEEE, pp. 31–36. doi:10.1109/CySWater.2016.7469060.
- Mauw, S., Oostdijk, M., 2005. Foundations of attack trees. In: International Conference on Information Security and Cryptology. Springer, pp. 186–198.
- Miller, R., Desborough, L., 2000. Web-enabled control loop assessment. *Chem. Eng.* 107 (5), 76–79.
- Morris, T., Srivastava, A., Reeves, B., Gao, W., Pavurapu, K., Reddi, R., 2011. A control system testbed to validate critical infrastructure protection concepts. *Int. J. Crit. Infrastruct. Prot.* 4 (2), 88–103. doi:10.1016/j.ijcip.2011.06.005.
- Paoletti, N., Jiang, Z., Islam, M.A., Abbas, H., Mangharam, R., Lin, S., Gruber, Z., Smolka, S.A., 2019. Synthesizing stealthy reprogramming attacks on cardiac devices. In: Proceedings of the 10th ACM/IEEE International Conference on Cyber-Physical Systems. ACM, pp. 13–22.
- Poudel, S., Ni, Z., Malla, N., 2017. Real-time cyber physical system testbed for power system security and control. *Int. J. Electr. Power Energy Syst.* 90, 124–133. doi:10.1016/j.jepes.2017.01.016.
- Prakash, J., Patwardhan, S.C., Shah, S.L., 2010. State estimation and nonlinear predictive control of autonomous hybrid system using derivative free state estimators. *J. Process Control* 20 (7), 787–799. doi:10.1016/j.jprocont.2010.04.001.
- Raskin, J.-F., 2005. An introduction to hybrid automata. In: Handbook of Networked and Embedded Control Systems. Springer, pp. 491–517.
- Sabalaiskaite, G., Mathur, A.P., 2015. Aligning cyber-Physical system safety and security. *Complex Syst. Des. Manag. Asia* 41–53. doi:10.1007/978-3-319-12544-2.
- Sridhar, S., Hahn, A., Govindarasu, M., 2012. Cyber-physical system security for the electric power grid. *Proc. IEEE* 100 (1), 210–224. doi:10.1109/JPROC.2011.2165269.
- Stallings, W., Brown, L., 2018. Computer security: Principles and Practice, (fourth ed.) Pearson.
- Stoneburner, G., Goguen, A., Feringa, A., 2002. Risk Management Guide for Information Technology Systems. Technical Report doi:10.6028/NIST.SP.800-30.
- Stouffer, K., Joe, F., Scarfone, K., 2015. Guide to industrial control systems (ICS) security. Technical Report. NIST. 800.82
- Thomas H. Cormen, C.E.L., 2009. Introduction to algorithms, third edition.
- Wu, Z., Albalawi, F., Zhang, J., Zhang, Z., Durand, H., Christofides, P.D., 2018. Detecting and handling cyber-attacks in model predictive control of chemical processes. *Mathematics* 6 (10), 1–22. doi:10.3390/math6100173.
- Ylmaz, E.N., Gönen, S., 2018. Attack detection/prevention system against cyber attack in industrial control systems. *Comput. Secur.* 77, 94–105. doi:10.1016/j.cose.2018.04.004.
- Zhang, Z., Wu, Z., Durand, H., Albalawi, F., Christofides, P.D., 2018. On integration of feedback control and safety systems: analyzing two chemical process applications. *Chem. Eng. Res. Des.* 132, 616–626.

Ashraf Tantawy received his Ph.D. in Electrical Engineering from Vanderbilt University, Nashville, TN, USA, in 2011. He is currently a Research Assistant Professor with the Electrical and Computer Engineering Department, Virginia Commonwealth University, Richmond VA, USA. His main research interest is Cyber Physical Systems, including CPS Security, Verifiable embedded hardware and software design, and Machine Learning integration with systems engineering.

Abdelkarim Erradi received his Ph.D. in Computer Science from the University of New South Wales, Sydney, Australia. He is currently an associate professor of Computer Science and Computer Engineering at Qatar University. His research interests include Web Services, Autonomic Computing, and Cloud Computing.

Sherif Abdelwahed is a Professor of Electrical and Computer Engineering at Virginia Commonwealth University, where he teaches and conducts research in the area of computer engineering, with specific interests in autonomic computing, cyber-physical systems, formal verification and cyber-security. Throughout his academic tenure, Dr. Abdelwahed pioneered work on model-based design of autonomic computing systems and self-managing systems using control-theoretic techniques and model-integrated computing concepts. Dr. Abdelwahed received the StatePride Faculty award for 2010 and 2011, the Bagley College of Engineering Hearin Faculty Excellence award in 2010, and the 2016 Faculty Research Award from the Bagley College of Engineering at MSU. He has more than 150 publications and is a senior member of the IEEE.

Khaled Shaban IEEE Senior Member, received his PhD degree from the Department of Electrical and Computer Engineering, University of Waterloo, Waterloo, Canada, in 2006. He is currently an Associate Professor with the Computer Science and Engineering Department, College of Engineering, Qatar University, Doha, Qatar. His research experience in academic and industrial institutions covers a variety of domains in intelligent systems applications and design.